



ENERSTAY
SUSTAINABILITY

2026 Edition
Audit Competence
Training Textbook

English Edition V1.6

ISO/IEC 42001:2023

Artificial Intelligence Management System
Audit Competence Training Course

AI governance • Audit practice • Competence enhancement • Responsible innovation

Chief Editors

Haizhou Wang | Yuanzhe Li

Enerstay Sustainability Pte. Ltd.

Contents

CORE CHAPTERS

- 1** Overview and AIMS fundamentals
- 2** Structural logic and audit thinking
- 3** Context, interested parties and scope
- 4** Leadership, policy and responsibilities
- 5** AI risk, opportunity and impact
- 6** Support processes and documented information
- 7** AI-system lifecycle and operational control
- 8** Annex A controls as audit subjects
- 9** Audit programme, planning and preparation
- 10** On-site techniques and evidence collection
- 11** Findings, nonconformities and audit reports
- 12** Industry cases and integrated exercises
- 13** Auditor competence development

Contents

PRACTICE APPENDICES

- A** Clauses and audit-focus reference
- B** Annex A controls and evidence
- C** AI-system inventory
- D** Risk and impact assessment form
- E** Statement of applicability
- F** Audit plan
- G** Audit checklist
- H** Interview question bank
- I** Nonconformity teaching examples
- J** Exercises and reference answers
- K** Bilingual terminology
- L** Annex A traceability master table
- M** Industry-case working-paper pack
- N** Auditor competence and witnessed-audit toolkit
- O** Course delivery and teaching conversion
- P** Figures and course visualization index
- Q** Final quality and delivery review
- R** References and extended standards

ISO/IEC 42001 Audit Competence Training Textbook

Complete English Edition V1.6

Professional English edition for audit competence training.

Standard Use and Copyright Boundary Notice

This textbook is a training and audit competence development material based on the management system logic of ISO/IEC 42001 and related AI governance practices. It is not the official text of ISO/IEC 42001, does not reproduce the clauses of the standard, and must not be used as a substitute for purchasing, reading or applying the official standard.

The purpose of the textbook is to help learners understand the management system logic, audit thinking, evidence route and competence requirements behind an artificial intelligence management system (AIMS). When an auditor performs certification, internal audit, supplier audit or second-party audit, the official standard, applicable audit criteria, certification rules, laws, contracts and organizational documented information shall remain the authoritative basis.

The examples, cases, templates, workpapers and exercises in this textbook are designed for training. They are not legal opinions, regulatory interpretations, technical validation conclusions or consulting schemes. Learners should use them to build audit judgement capability, not to replace professional legal, technical, medical, financial or regulatory review where such review is required.

Publication status update (verified on 15 August 2026)

As of this verification date, ISO/IEC 42001:2023 remains the published Type A management system standard for artificial intelligence management systems. ISO/IEC 42005 has been published as ISO/IEC 42005:2025 for AI system impact assessment, so draft-year wording should no longer be used for that reference.

ISO/IEC 42006 has been published as ISO/IEC 42006:2025 for bodies providing audit and certification of artificial intelligence management systems. It supplements certification-body and accreditation logic; it does not convert certification-body requirements into auditee obligations.

Regulation (EU) 2024/1689, the Artificial Intelligence Act, entered into force on 1 August 2024 and applies progressively. The Digital Omnibus on AI, Regulation (EU) 2026/1744, entered into force on 27 July 2026 and amended several implementation dates. GPAI provider obligations have applied from 2 August 2025; the broader 2026 application stage, transparency obligations and later high-risk transition dates should be checked for the auditee's jurisdiction, role and AI use case before being used as audit criteria.

Textbook Positioning

This textbook is written for ISO/IEC 42001 audit competence training. Its primary audience includes management system auditors, certification body personnel, internal auditors, compliance and risk professionals, AI governance managers, information security and privacy practitioners, AI product and lifecycle owners, and training providers that need to convert ISO/IEC 42001 knowledge into structured courses.

The textbook is positioned as a foundational but practice-oriented manual. It does not attempt to turn auditors into algorithm engineers, nor does it reduce AI management system auditing to a generic IT checklist. Its central task is to help learners understand how AI-specific risk, impact, lifecycle, data, human oversight, transparency and third-party dependence are brought into the management system audit route.

Readers should use the textbook together with the official ISO/IEC 42001 standard and, where applicable, ISO/IEC 22989, ISO/IEC 23894, ISO/IEC 42005, ISO/IEC 27001, ISO 19011, ISO/IEC 17021-1 and relevant certification or regulatory requirements. The textbook explains how to learn and audit; it does not replace normative documents.

Preface

Artificial intelligence is moving from isolated technical experimentation into products, services, decision processes, internal tools and public-facing systems. Organizations are no longer asking only whether an AI model works. They also need to know whether AI is governed, whether responsibilities are clear, whether risks and impacts are assessed, whether controls are selected and implemented, whether operation is monitored, and whether problems lead to improvement.

ISO/IEC 42001 provides a management system approach for these questions. For auditors, however, a new difficulty appears. AI systems contain data, models, prompts, lifecycle changes, third-party services and human-machine interactions. If auditors audit only files, they may miss actual system behavior. If auditors chase only technical indicators, they may lose the management system boundary. The competence needed is therefore a compound competence: management system thinking, AI literacy, risk and impact sensitivity, evidence discipline and professional restraint.

This textbook follows that competence logic. It begins with the purpose and structure of ISO/IEC 42001, then moves to context, scope, leadership, risk, support processes, lifecycle control, Annex A controls, audit planning, on-site audit, findings and reports, industry cases, auditor competence and practical appendices. The book repeatedly uses the audit route of requirement, implementation, evidence and judgement. This route is the thread that connects standards, organizational practice and audit conclusions.

How to Use This Textbook

For learners new to ISO/IEC 42001, the recommended route is to read Chapters 1 to 3 first, so that the basic concept of AIMS, the structure of the standard, and the scope and interested-party logic are understood. Chapters 4 to 8 then explain the main audit subjects: leadership, risk and impact assessment, support processes, lifecycle control and Annex A control themes. Chapters 9 to 11 convert these subjects into audit planning, on-site evidence collection and audit reporting. Chapters 12 and 13 should be used for case training and auditor competence development.

For experienced management system auditors, the most important adjustment is not learning a completely new audit method, but adapting existing audit principles to AI scenarios. Such readers may focus on Chapter 2, Chapter 5, Chapter 7, Chapter 8, Chapter 10 and Chapter 12. These chapters show how process approach, risk-based thinking, evidence sufficiency, sampling and nonconformity writing change when the audit object includes AI systems.

For course designers and instructors, the appendices provide templates, checklists, question banks, exercises, case workpapers, competence evaluation tools and course implementation suggestions. They can be converted into slides, classroom group work, case simulations, examination questions and digital-human lecture scripts.

Learning Path and Course Conversion Suggestions

The textbook can support several training formats. A one-day awareness course may use Chapters 1 to 3, selected sections of Chapters 5 and 8, and several short exercises from Appendix J. A three-day foundation and internal auditor course may cover Chapters 1 to 11 and use the interview bank, audit checklist and nonconformity examples. A five-day auditor competence course should add the industry case exercises, auditor competence evaluation tools and working-paper practice.

In course conversion, instructors should avoid turning the book into a slide deck that simply repeats headings. The value of the textbook lies in the movement from concept to evidence. Each teaching unit should therefore include at least one audit question, one evidence example, one judgement boundary and one learner task. For example, the topic of impact assessment should not stop at explaining what impact assessment is. It should ask learners to identify affected parties, review an assessment record, judge whether it matches actual use, and decide what further evidence is needed.

The appendices should be used actively. Appendix H supports interview simulation. Appendix J supports staged learning evaluation. Appendix M supports case workpapers. Appendix N supports auditor competence evaluation. Appendix O supports course scheduling and teaching design. Appendix Q supports publication-level quality review and later maintenance.

Quick Reference for Terms and Abbreviations

For the structured audit reference used in this section, see Table FM-1.

Table FM-1. Quick Reference for Terms and Abbreviations - Term or Abbreviation, Recommended

English Use, Teaching Note

Term or Abbreviation	Recommended English Use	Teaching Note
AIMS	AI management system	Use consistently for the management system established for AI.

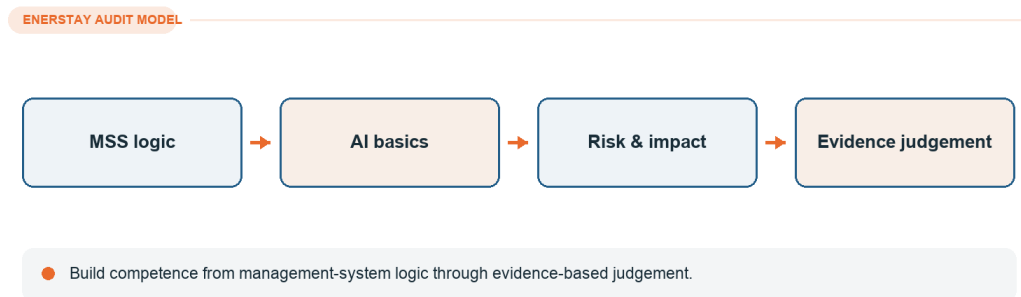
Term or Abbreviation	Recommended English Use	Teaching Note
AI system	AI system	Do not replace with model unless the discussion is only about the model component.
SoA	statement of applicability	The SoA connects risk treatment, control selection and implementation evidence.
AI risk assessment	AI risk assessment	Distinguish from impact assessment.
AI system impact assessment	AI system impact assessment	Focuses on impacts on individuals, groups, society, organizations and interested parties.
documented information	documented information	Use ISO management system language.
audit criteria	audit criteria	Includes standards, procedures, contracts and applicable obligations.
audit evidence	audit evidence	Evidence must be objective, sufficient and traceable.
audit finding	audit finding	May include conformity, nonconformity, risk note or opportunity for improvement.
nonconformity	nonconformity	Do not write consulting suggestions as nonconformities.
corrective action	corrective action	Should address cause and effectiveness, not only correction.
residual risk	residual risk	Risk remaining after treatment.
human oversight	human oversight	Must be substantive, not merely nominal approval.
lifecycle	lifecycle	Covers design, development, validation, deployment, operation, change and retirement.

Term or Abbreviation	Recommended English Use	Teaching Note
Harmonized structure (HS)	harmonized structure	Official current ISO term for the common MSS structure; use when explaining ISO/IEC 42001 integration.
Annex SL (legacy reference)	legacy wording	Older training reference for high-level structure wording; do not use as the primary current term.

1 Overview of ISO/IEC 42001 and Artificial Intelligence Management Systems

Figure 1 sets the opening learning route: an ISO/IEC 42001 auditor needs management-system judgement, AI-system understanding, risk and impact assessment competence, evidence tracing and report-writing discipline to work together.

Figure 1. Auditor Competence Model



The emergence of an artificial intelligence management system is not caused by an organization's sudden need for another set of documents. It is caused by the fact that AI systems change the way organizational risk and responsibility are created. In a traditional management system, an organization can often build controls around relatively stable products, processes, equipment, people and suppliers. AI systems introduce additional complexity: model behaviour may depend on training data and operating data and may continue to vary over time; outputs may affect individual opportunities, customer rights, business decisions and public trust; performance that appears acceptable in a test environment may change in real use because of data drift, user behaviour, external attack, prompt manipulation or changing business rules.

For this reason, learning ISO/IEC 42001 should not begin with mechanical memorization of clauses. Learners should first understand the basic management problems that an AIMS is intended to solve. Why does the organization use AI? Which processes are affected by AI systems? Which interested parties may be affected? How are responsibilities allocated? How are risks and opportunities identified? How are AI system impacts assessed? How are controls selected? How does the organization prove that the controls operate? How does it improve when deviations are found? These questions form the real audit route for an AI management system.

For auditors, this chapter establishes the starting point: ISO/IEC 42001 is not a single technical standard, and an audit is not merely an extension of model testing. It is a systematic evaluation of organizational governance, risk treatment processes and operating evidence. Without this understanding, later study of clauses, controls, cases and tools easily becomes fragmented.

1.1 Why AI Governance Requires a Management System

Many organizations first introduce AI from the perspective of efficiency and innovation. A customer service department may want intelligent customer service to reduce pressure on human agents. A financial institution may want a scoring model to improve approval efficiency. A manufacturer may want visual inspection to improve defect detection. A human resources department may want resume screening to reduce initial review workload. A development team may want generative AI to accelerate code, documents or design output. These applications have clear business appeal, but they also move the organization into new risk boundaries.

One feature of AI risk is that technical performance and management responsibility do not always move together. A model may perform well on a test set, but that does not mean it will avoid bias across all real populations, business scenarios and use periods. A generative AI tool may improve employee productivity, but that does not mean the organization has handled data leakage, incorrect output, intellectual property, customer misunderstanding and accountability. A supplier's AI service may pass a technical demonstration, but that does not mean the purchasing organization has defined data processing, model updates, incident notification, service limits and exit mechanisms.

The value of a management system is that it converts these dispersed risks into governable organizational processes. It requires the organization not only to "know that AI is being used", but also to identify which AI systems are within

scope, define who is responsible for them, evaluate their risks and impacts, select suitable controls, provide resources and competence, monitor operating results, and take correction and improvement when problems occur. In other words, the management system lifts AI governance from personal experience, project self-discipline and ad hoc approval to an institutional capability.

Auditors should avoid two extremes. One extreme is treating an AIMS as an ordinary management system with a new name, as if policy, objectives, procedures and records were sufficient. The other extreme is treating an AIMS as a highly technical model review that only algorithm specialists can judge. Real audits sit between these extremes. Auditors need enough understanding of AI systems and risk sources to ask meaningful questions, but the core audit question remains whether the organization has established appropriate, effective and verifiable management mechanisms.

1.2 Standard Positioning and Applicable Organizations

ISO/IEC 42001:2023 is an international standard for artificial intelligence management systems. According to public ISO and IEC descriptions, it specifies requirements and provides guidance for establishing, implementing, maintaining and continually improving an AI management system within an organizational context, and it is applicable to organizations providing or using products or services that use AI systems. It is not limited to a particular organization size, type or industry, and it is not only for AI technology companies. Any organization that provides or uses AI systems in products, services, management activities or business processes may need to consider its relevance.

This broad applicability creates a higher demand on auditors. Auditing an AI credit model in a financial institution is not the same as auditing a visual inspection system in manufacturing, a generative AI service in a software company, an auxiliary diagnostic tool in a hospital, or an internal office AI assistant. In different scenarios, the intended use, interested parties, risk level, data sources, human intervention, regulatory context and acceptable risk all change. Auditors cannot apply one fixed set of questions mechanically. They should use the common logic of the standard and then tailor sampling and judgement to the organization's actual scope and risk.

Another important positioning point is that ISO/IEC 42001 is a management system standard. A management system standard does not focus on whether individual controls exist in isolation. It focuses on whether the organization can achieve intended results through a set of interrelated elements. For an AIMS, these elements include context, leadership, planning, support, operation, performance evaluation and improvement. AI lifecycle, data governance, impact assessment, interested-party communication, third-party relationships and use controls need to be embedded in this management system logic rather than treated as disconnected files or technical activities.

Learners should also understand the relationship between ISO/IEC 42001 and laws and regulations. The standard provides a management framework and helps organizations meet applicable obligations and interested-party expectations more systematically, but it does not replace AI regulations, data protection laws, industry regulatory requirements or contractual obligations in any jurisdiction. When auditors evaluate whether an organization has identified and considered applicable requirements, they may review compliance identification, responsibility allocation and implementation of controls, but they should not convert an AIMS audit directly into a legal compliance conclusion.

1.3 Relationship Between AIMS and Other Management Systems

Many organizations preparing to implement ISO/IEC 42001 already operate ISO 9001, ISO/IEC 27001, ISO/IEC 27701, ISO 20000-1, ISO 22301 or other management systems. For these organizations, an AIMS does not necessarily need to be built from zero. A mature approach is often to identify structures that can be reused: context analysis, policy and objective management, documented information control, internal audit, management review, corrective action, supplier management, information security risk assessment and business continuity arrangements. The organization then supplements these with AI-specific risks, impacts, lifecycle, data and transparency controls.

This integration reduces duplication, but it also creates audit challenges. An organization may claim that AI management is integrated into an existing system, while the actual evidence remains at the level of information security or quality management and lacks targeted arrangements for AI system impact assessment, AI resources, data quality, model monitoring, human oversight, interested-party information and third-party AI service management. Auditors should not assume AIMS effectiveness merely because the organization holds other certifications. They need to check whether AI-specific requirements have entered processes, responsibilities, records and improvement mechanisms.

ISO/IEC 27001 provides a useful example. An information security management system focuses on confidentiality, integrity and availability of information assets and provides important foundations for AI systems, such as access control, supplier security, incident management, logging and risk assessment. However, an AI management system must also consider bias, insufficient transparency, deviation from intended use, degradation of model performance,

impacts of automated decision support and social or ethical concerns. The two systems support each other, but neither replaces the other.

ISO 9001 provides another example. A quality management system emphasizes process approach, customer requirements, performance evaluation and continual improvement. This logic is highly compatible with AIMS. Yet the "quality" of an AI system is not only product conformity or service satisfaction. It may involve representativeness of training data, output stability, abnormality handling, model update control and user understanding. If an organization simply places AI projects into a normal design and development process without identifying AI-specific risks, it will be difficult to meet AIMS audit expectations.

1.4 AI Risk, Opportunity, Responsibility and Organizational Governance

The core of ISO/IEC 42001 is not to require organizations to avoid AI, but to require organizations to develop, provide or use AI systems responsibly. "Responsible" is not merely a value statement. It should be visible in governance arrangements: whether top management understands the impact of AI on organizational objectives and interested parties; whether policy and objectives are established; whether responsibilities are clear; whether risks and impacts are evaluated; whether resources are allocated; whether performance is monitored; and whether corrective action is taken after problems occur.

AI brings both risks and opportunities. Risks may include wrong decisions, discriminatory outcomes, privacy leakage, security vulnerabilities, loss of control over models, supplier dependence, compliance failure, customer misunderstanding and reputational damage. Opportunities may include efficiency improvement, better service accessibility, more stable quality, stronger prediction capability, earlier risk warning and greater innovation. A mature AIMS should not write only risk lists, nor should it only promote innovation benefits. It should consider risks and opportunities together in relation to organizational objectives, business processes and interested-party expectations.

Responsibility is easily weakened in AI governance. In a traditional software project, responsibility may be allocated around product owners, development leads, operations leads and business owners. In an AI system, responsibility boundaries are more complex and may involve data providers, model developers, system integrators, business users, suppliers, compliance teams, customers and affected individuals. Auditors should examine whether the organization has clarified these relationships, especially when model outputs are wrong, data is biased, users misuse the system, a supplier updates a model or an external complaint occurs. Who identifies, escalates, handles and communicates the issue?

From a governance perspective, AI management should enter organizational decision-making, not stay inside technical team documents. Top management demonstrates leadership through resources, policy and objectives, risk acceptance, management review and improvement decisions. Middle managers embed AI control requirements into business processes. Technical personnel retain evidence of design, validation, deployment, monitoring and change. User departments use systems according to intended use and report problems. Internal audit and management review evaluate effectiveness. Only when these levels work together can an AIMS become a real management system.

1.5 Competence Model for Learning ISO/IEC 42001 Audit

ISO/IEC 42001 auditor competence can be understood in four layers. The first layer is basic management system competence: high-level structure, process approach, risk-based thinking, documented information, internal audit, management review, corrective action and continual improvement. Without this layer, an auditor may turn an audit into document collection or checklist ticking.

The second layer is basic AI understanding. Auditors do not need to master every algorithm, but they should understand the differences between AI systems and ordinary information systems, and the basic concepts of training data, models, inference, verification, validation, monitoring, data drift, bias, explainability, human oversight and third-party model services. Without this layer, auditors struggle to ask effective questions or judge whether technical materials are relevant to risks and controls.

The third layer is risk and impact assessment competence. Risks in an AI management system are not only directed at the organization itself. They may also affect individuals, groups, society and other interested parties. Auditors should be able to judge whether the organization has identified intended use, affected parties, potential harm, misuse scenarios, controls and residual risks. They should also be able to distinguish and connect risk assessment, impact assessment, information security risk assessment and ordinary project risk management.

The fourth layer is audit evidence and judgement competence. Auditors need to convert standard requirements into verifiable questions, turn interview information into evidence leads, cross-check documents and records, and form audit findings when evidence is sufficient. AI audits often involve complex terminology, unclear system boundaries,

insufficient supplier information and inconsistent explanations between business and technical teams. Auditor maturity is often shown by the ability to grasp the management system evidence chain within complex information, rather than being pulled away from audit criteria by technical details.

For a reviewable classroom or audit-preparation format, see Table 1-1.

Table 1-1. Competence Model for Learning ISO/IEC 42001 Audit - Competence Layer, Key Competence, Audit Manifestation

Competence Layer	Key Competence	Audit Manifestation
Management system competence	Understand clause structure, process approach and PDCA	Identifies whether the system actually operates, not only whether documents exist
Basic AI understanding	Understand AI systems, data, models, validation and monitoring	Communicates with technical teams and asks effective audit questions
Risk and impact assessment competence	Understand AI risks, interested-party impacts and control selection	Judges whether risk assessment, impact assessment and SoA are consistent
Evidence and judgement competence	Build evidence chains from documents, records, interviews and observation	Forms objective, traceable and well-bounded audit findings

1.6 From AI Use Inventory to AIMS Implementation Path

When learning ISO/IEC 42001, auditors need to connect "what AI the organization uses" with "how the organization governs that AI". Many organizations start AIMS implementation by writing policies, procedures, risk forms and control lists, without first building a clear AI use inventory. This creates a system that starts from documents rather than from real business. For auditors, the AI use inventory is not only evidence for scope audit. It is also a key entrance for judging whether risk assessment, impact assessment, control selection and sampling strategy are sufficient.

An AI use inventory should cover AI systems that the organization provides, develops, deploys, procures, integrates or uses internally. A "system" is not necessarily a large platform. It may be a model service embedded in a business process, an automated recommendation component, a generative AI office tool, an intelligent analytics module provided by a supplier, or a customer service chatbot. When reading the inventory, auditors should look beyond system names and examine intended use, business process, responsible department, users or affected parties, data type, supply mode, lifecycle status, risk level and key controls. Only with this level of specificity can later AIMS planning rest on a sound basis.

From the AI use inventory, a relatively stable implementation path can be formed. The organization first identifies AI systems and business scenarios, then determines which systems are within the management system scope. On that basis, it identifies interested parties and applicable requirements, defines role responsibilities and governance structure, evaluates AI risks and impacts, selects controls and creates the SoA. It then implements controls in lifecycle, data, supplier, use, monitoring and communication processes, and finally achieves continual improvement through internal audit, management review, incident handling and corrective action. Auditors should use this path to test whether the AIMS grows out of real AI activity rather than from a template.

This path is also an entry map for auditors. Beginners often worry that AI technology is too complex and do not know where to start. In practice, auditors can begin with three questions: where are the organization's AI systems; why are they included or excluded; and how does the organization prove that these systems are managed? Once these questions are clear, many audit trails naturally appear. A system affecting customer rights leads to interested parties, transparency, complaints and human review. A system relying on a supplier model service leads to supplier evaluation, contractual responsibility, change notification and incident reporting. A system that learns or changes frequently leads to change control, performance monitoring and review mechanisms.

To connect this section's explanation with practical audit evidence, see Table 1-2.